

Social Engineering Awareness Simulation & Training Report



Bonus Challenge

Cybersecurity Internship Assignment

Student: Noor Fatima

DHC-1885

Date: May 19, 2026

1. Introduction

Social engineering is one of the most dangerous and effective attack techniques used by cybercriminals today. Unlike technical attacks that exploit software vulnerabilities, social engineering exploits human psychology manipulating people into revealing confidential information, clicking malicious links, or granting unauthorized access.

According to cybersecurity research, over 90% of successful data breaches involve some form of social engineering. This report documents simulated social engineering attack scenarios, analyzes how they work, and provides awareness training and prevention guidelines.

Scope: This report is for educational and awareness purposes only. All scenarios described are simulated and documented to help users recognize and avoid real attacks. No actual attacks were performed.

2. Types of Social Engineering Attacks

Attack Type	Description	Risk Level
Phishing	Fraudulent emails or messages impersonating trusted organizations to steal credentials or install malware	HIGH
Spear Phishing	Targeted phishing attacks aimed at specific individuals using personal information	CRITICAL
Vishing	Voice phishing phone calls impersonating banks, IT support, or government agencies	HIGH
Smishing	SMS phishing fake text messages with malicious links	MEDIUM
Pretexting	Creating a fabricated scenario to manipulate someone into providing information	HIGH
Baiting	Leaving infected USB drives or offering fake downloads to install malware	MEDIUM
Tailgating	Physically following authorized personnel into restricted areas	MEDIUM
Quid Pro Quo	Offering a service in exchange for information (e.g., fake IT support)	HIGH

3. Simulated Phishing Attack Scenario

Scenario 1 Fake IT Support Email

Attack Description:

An attacker sends an email impersonating the company IT department. The email claims the user's account will be suspended within 24 hours unless they verify their credentials by clicking a link. The link leads to a fake login page that looks identical to the real company portal.

Simulated Email Content:

From: it-support@company-secure.com (FAKE)
Subject: URGENT: Your account will be suspended in 24 hours
Dear Employee, We have detected unusual activity on your account.
Click here to verify: <http://company-portal-secure.fake.com/login>

Red Flags to Identify:

1. Sender domain is company-secure.com not the real company domain
2. Creates urgency with 24 hour deadline to pressure quick action
3. Link URL does not match the real company website
4. Asks you to click a link and enter credentials
5. Generic greeting instead of your actual name

Scenario 2 Fake Password Reset

Attack Description:

An attacker sends a fake password reset email claiming the user requested a password change. If the user clicks the link and enters their old and new password, the attacker captures their current credentials.

Red Flags to Identify:

1. You did not request a password reset
2. The link goes to an unfamiliar domain
3. The email asks for your current password legitimate reset forms never ask for your old password
4. Poor grammar or spelling in the email

Scenario 3 Fake Job Offer (Spear Phishing)

Attack Description:

An attacker researches a target on LinkedIn and sends a personalized job offer email. The email contains a PDF attachment labelled as a job description. When opened, the PDF installs malware on the victim's machine.

Red Flags to Identify:

1. Unsolicited job offer from an unknown recruiter

2. Attachment is a PDF or Word document from an unknown sender
3. Email asks you to enable macros or allow content in the document
4. The offer seems too good to be true

4. How to Recognize a Phishing Attack

Warning Sign	What to Look For	Action
Suspicious sender	Domain doesn't match the real organization	Do not click any links
Urgency / threats	Account suspended, verify now, limited time	Stop and verify through official channels
Suspicious links	Hover over links to see the real URL before clicking	Never click if URL looks wrong
Requests for credentials	Asking for password, OTP, or personal info	Legitimate orgs never ask for passwords via email
Unexpected attachments	PDFs, Word docs, ZIP files from unknown senders	Do not open attachments from unknown senders
Poor grammar	Spelling mistakes, awkward phrasing	Treat with suspicion
Generic greetings	Dear Customer, Dear User instead of your name	Could indicate mass phishing attempt

5. Prevention Guidelines

For Individual Users

1. Always verify the sender email address before clicking any link
2. Never enter your credentials on a page you reached by clicking an email link go directly to the website instead
3. Enable two-factor authentication on all accounts
4. Never share your password with anyone including IT support
5. When in doubt, call the organization directly using a number from their official website
6. Keep your operating system and antivirus software updated
7. Report suspicious emails to your IT or security team immediately

For Organizations

1. Conduct regular phishing awareness training for all employees
2. Run simulated phishing campaigns to test employee awareness

3. Implement email filtering and anti-phishing tools
4. Use DMARC, DKIM, and SPF email authentication to prevent email spoofing
5. Enforce multi-factor authentication across all systems
6. Create a clear process for employees to report suspicious emails
7. Establish a zero trust policy verify every request regardless of source

6. Technical Defenses Implemented in Our Application

Our web application already implements several technical defenses that reduce the risk of social engineering attacks succeeding even if a user is tricked:

Defense	How It Helps Against Social Engineering
JWT Token Authentication	Even if credentials are stolen, tokens expire after 1 hour
bcrypt Password Hashing	Stolen database does not reveal actual passwords
Rate Limiting	Blocks brute force attacks after stolen credentials are used
CSRF Protection	Prevents attackers from making requests on behalf of logged in users
Zero Trust Policy	Every request verified independently no implicit trust
WAF	Blocks malicious payloads even if attacker gains partial access
Winston Logging	All suspicious activity is logged for investigation

7. Simulation Findings Summary

Scenario	Attack Type	Success if Untrained	Prevented By
Fake IT Support Email	Phishing	High	Awareness training, email verification
Fake Password Reset	Phishing	High	Never enter credentials from email links
Fake Job Offer PDF	Spear Phishing	Medium	Never open attachments from unknown senders
Fake Login Page	Credential Harvesting	High	Check URL, use password manager

8. Conclusion

Social engineering attacks are highly effective because they target human psychology rather than technical systems. No amount of technical security can fully protect an organization if its users are not trained to recognize and respond to these attacks.

The simulated scenarios in this report demonstrate how convincing phishing attacks can be and highlight the importance of user awareness training. Combined with the technical defenses implemented in our application throughout this internship including JWT authentication, bcrypt hashing, rate limiting, CSRF protection, Zero Trust security, and WAF we have built a comprehensive security posture that addresses both technical and human vulnerabilities.

The key takeaway is: always verify before you trust, and when in doubt, do not click.

8. References

1. OWASP Social Engineering: https://owasp.org/www-community/attacks/Social_Engineering
2. SANS Security Awareness: <https://www.sans.org/security-awareness-training/>
3. Anti-Phishing Working Group: <https://apwg.org>
4. NIST Phishing Guidance: <https://www.nist.gov/phishing>
5. Cybersecurity and Infrastructure Security Agency: <https://www.cisa.gov/phishing>